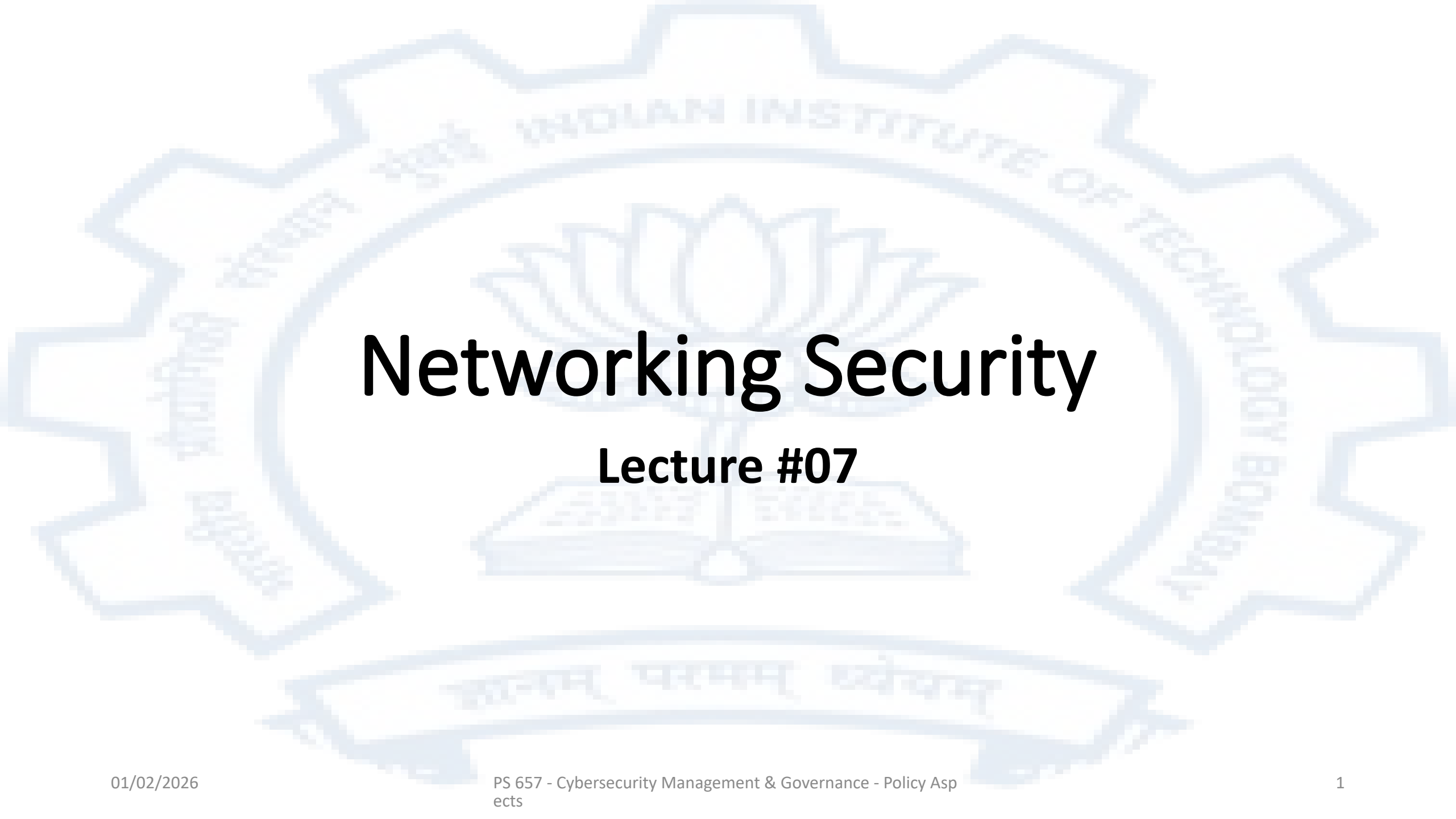


The background of the slide features a large, light blue watermark of the Indian Institute of Technology Bombay logo. The logo is circular with a gear-like outer border. Inside the circle, there is a lotus flower in the center, and the text "INDIAN INSTITUTE OF TECHNOLOGY BOMBAY" is written in a circular path around the lotus. At the bottom of the logo, there is a banner with text in Sanskrit.

Networking Security

Lecture #07

Network Security Goals

- Confidentiality
- Integrity
- Availability

As an example, for an email system it is important that nobody other than the sender and recipient(s) be able to access the email. It is important that nobody is able to alter the contents of a message that is being transmitted. Finally it is important that the communication channels should not be swamped with so much traffic by a malicious agent that legitimate users are not able to use the system

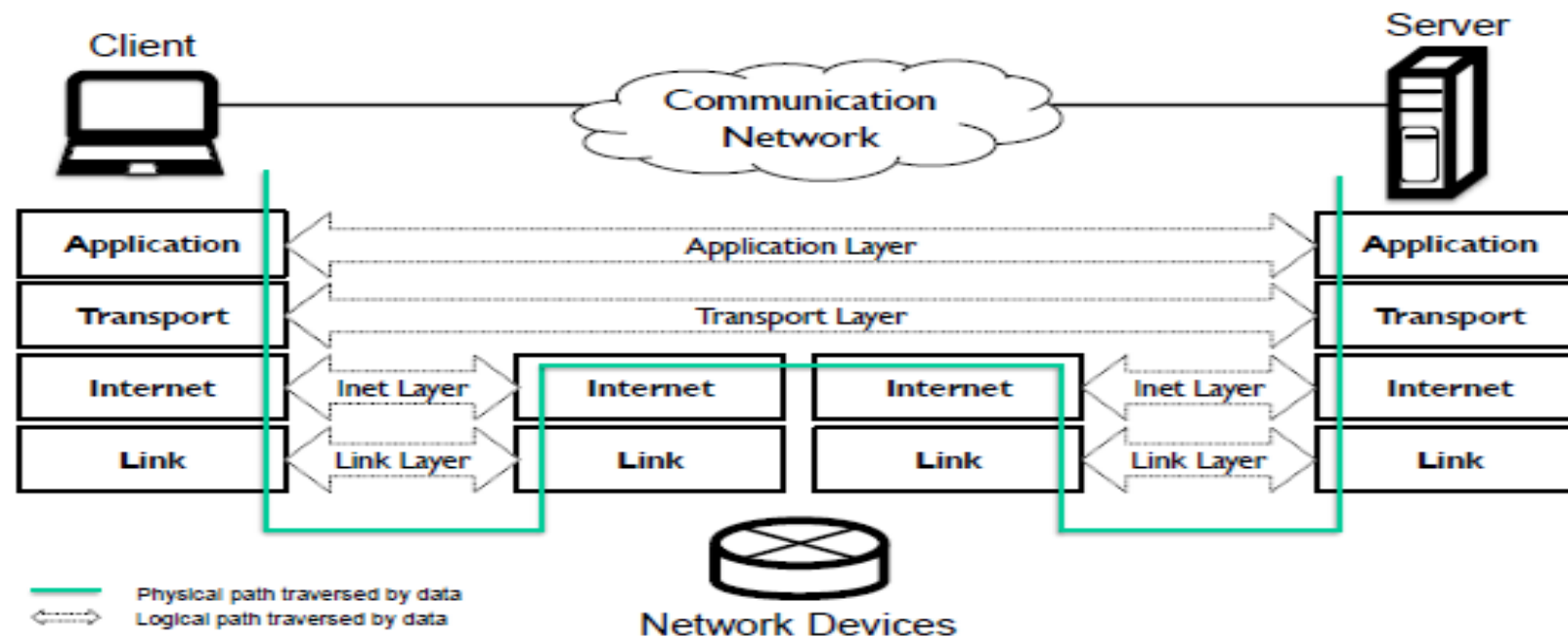
Types of attackers

- Where they are positioned
 - Internal
 - In path
 - Off path
 - External
 - In path
 - Off path
- Who they are
 - Individual users
 - Groups of users controlled by some entity
- What capabilities they have
 - Passive (can only eavesdrop)
 - Active (can modify/inject traffic)

Deployment of networking

- Local Area Networks (LANs)
- Connected Networks and the Internet
- Bus Networks
- Wireless Networks
- Fully Distributed Networks
- Software Defined Networks and Virtualization of Network Functions

Network Protocols



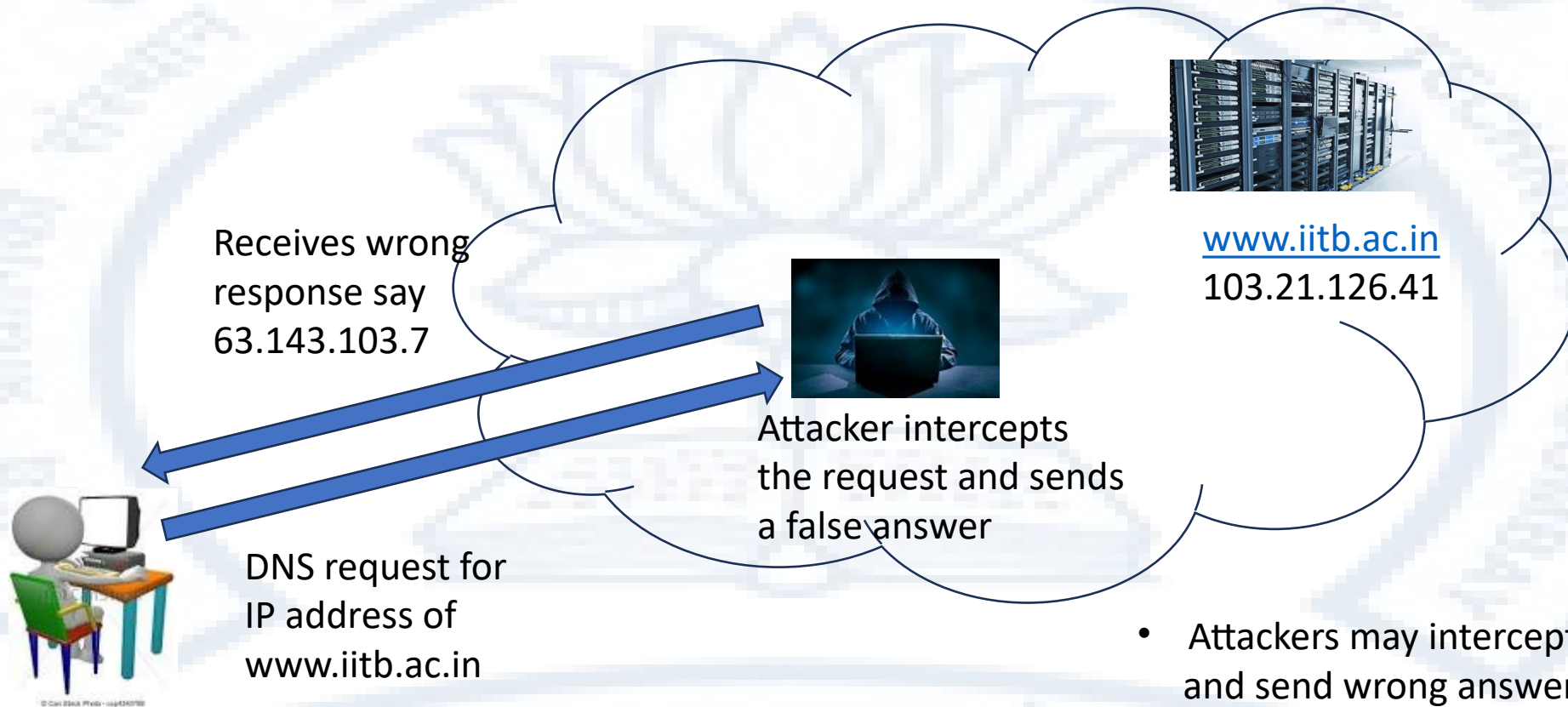
Security at the Application Layer

- Email security
 - The basic email protocol SMTP lacks any security features
 - The two major email security schemes are PGP and S/MIME
 - Both require each user to have a public-private key pair
 - End-to-End encryption can be achieved via these schemes
- Messaging security
 - The same basic method is used by messengers like Signal, WhatsApp and some other conferencing application to achieve end-to-end encryption
- Web connection security
 - The HTTP protocol lacks security features
 - HTTPS provides a security wrapper over HTTP and operates based on server certificates-private key pairs and optionally provides for client certificates as well

Security at the Application Layer- continued

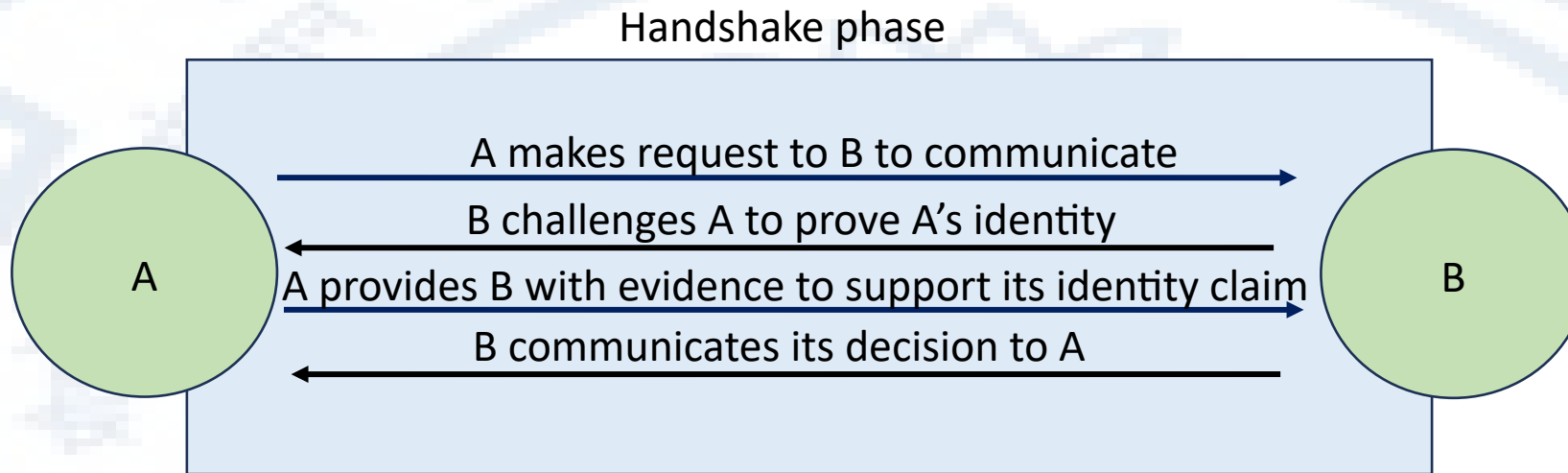
- Network Time Protocol
 - In principle NTP uses a set of hierarchical servers and digital signatures
 - In practice the digital signatures are often not implemented
 - A mitigation strategy could be to install local NTP servers and have then resynchronize with several other servers periodically
- Anonymous and Censorship-Free Communication
 - This is contentious because not all countries/societies have the same understanding of free communication
 - However in some scenarios loss of anonymity can have serious consequences
 - Onion routing is the de-facto standard in this area and Tor is the most popular implementation

Security at the Application layer- DNS Security



- Attackers may intercept DNS requests and send wrong answers
- Those wrong answers may lead users to malicious sites
- DNSSEC is a protocol that aims to ensure correctness of DNS queries

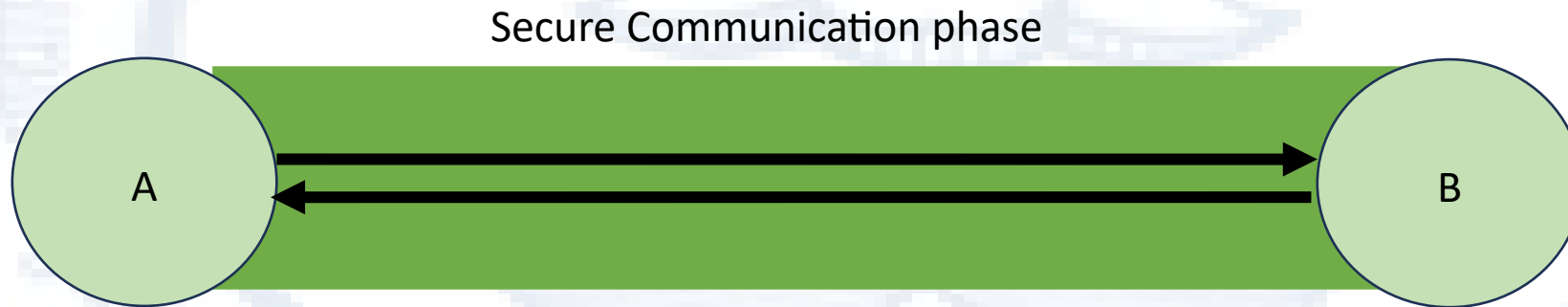
A template for communications security



1. At the end of the handshake phase
2. A should be certain that it has communicated with B
3. B should be certain that it has communicated with A
4. A and B should have been able to negotiate a secret from which both can compute a shared key suitable for use with a symmetric encryption system

A template for communications security- contd

- Typically both A and B will have Digital Certificates
- Any communication is digitally signed by the sender
- During exchanges for authentication or key negotiation secret data for a recipient is encrypted using the recipients public key



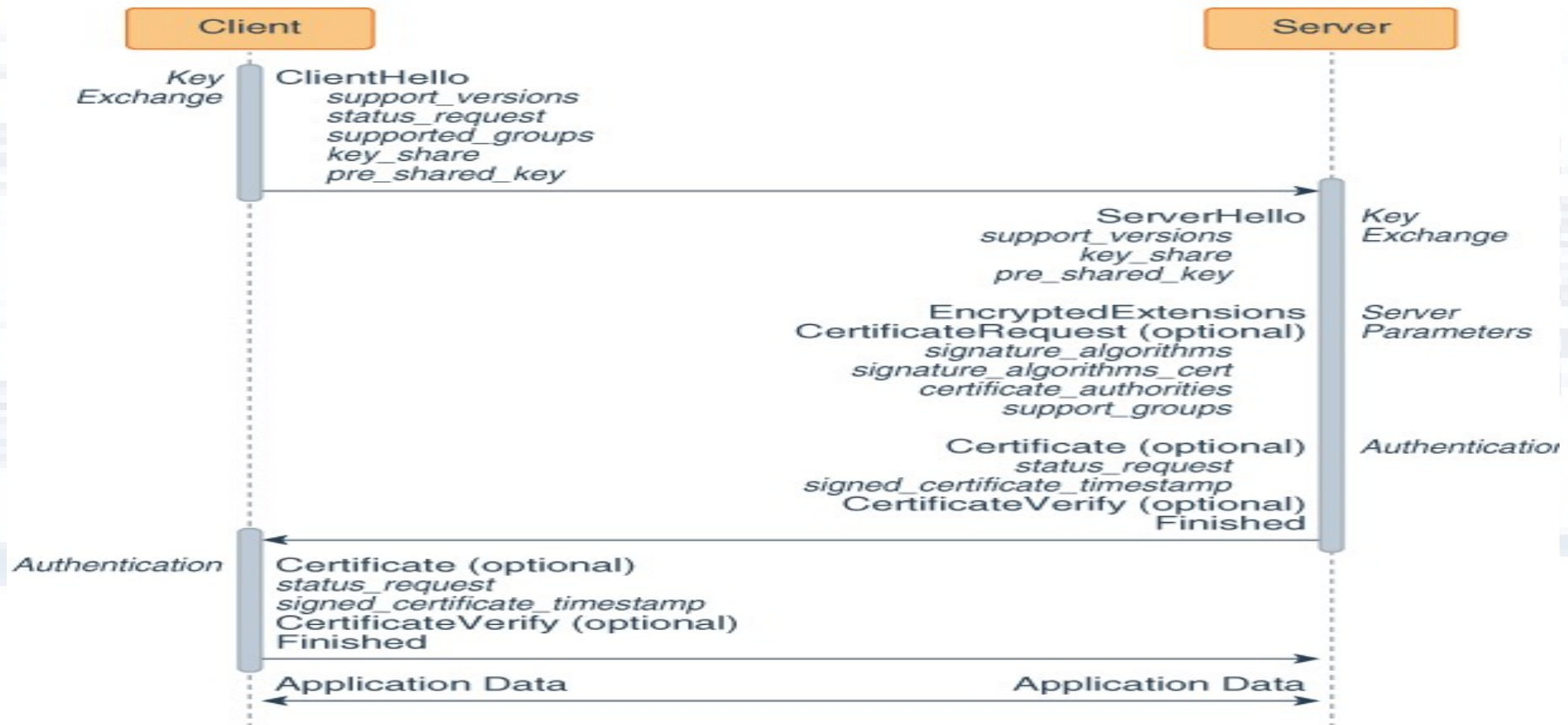
- Why should we not directly encrypt using recipient public keys?
 - Symmetric key encryption is much faster than asymmetric key encryption
 - Asymmetric key encryption increases message size since ciphertexts are longer than plain texts

Security at the Transport Layer- TLS

- TLS is one of the most widely deployed transport layer security protocols
- The protocol involves a phase where the client and server enter into a handshake where they authenticate each other, negotiate a key and a cryptographic algorithm to use for the secure communication phase

TLS 1.3 Handshake

<https://www.ibm.com/docs/en/sdk-java-technology/8?topic=handshake-tls-13-protocol>



Explanation of the TLS 1.3 handshake

1. Key exchange:
 - a. The client sends a ClientHello message to server.
 - b. The server processes the ClientHello message and determines the appropriate cryptographic parameters for the connection. It then responds with its own ServerHello message, which indicates the negotiated connection parameters. For TLS 1.3, the ServerHello message determines the key and cipher options only. Other handshake parameters may be determined later.
2. Server parameters: The server sends two messages to establish server parameters:
 - EncryptedExtensions: This message contains responses to ClientHello extensions that are not required to determine the cryptographic parameters, other than those that are specific to individual certificates.
 - CertificateRequest (optional): If certificate-based client authentication is desired, then the server sends this message, which contains the desired parameters for that certificate. This message is omitted if client authentication is not desired.
3. Authentication:
 - a. The server sends these authentication messages:
 - Certificate (optional): This message contains the authentication certificate and any other supporting certificates in the certificate chain. This message is omitted if the server is not authenticating with a certificate.
Note: The Certificate message can contain a raw key instead of a certificate.
 - CertificateVerify (optional): This message contains a signature over the entire handshake using the private key corresponding to the public key in the Certificate message. This message is omitted if the server is not authenticating with a certificate.
 - Finished: a MAC (Message Authentication Code) over the entire handshake.
 - b. The client responds with its own Certificate, CertificateVerify, and Finished messages. The Certificate message is omitted if the server did not send a CertificateRequest message. The CertificateVerify message is omitted if the client is not authenticating with a certificate.

The client and server can now securely send application data to each other.

Deploying TLS

- The granularity of encryption is a TCP socket
- The application must make explicit secure socket calls
- To secure an existing application that uses ordinary sockets calls
 - The application must be recoded to use secure sockets
 - Deploy an external TLS tool as a VPN and route application traffic over that. This will degrade performance and will Create an unencrypted zone between application server/client ingress/egress and the tunnel endpoints

Network Layer Security – IPv4

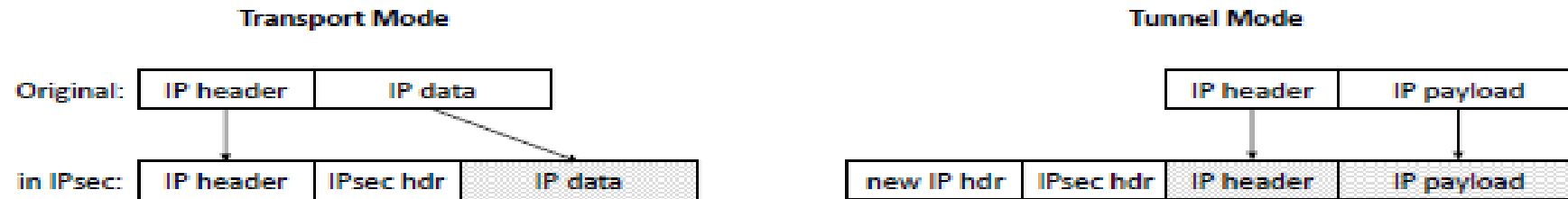
- IP Spoofing
 - The design of the IP protocol allows a process to send out arbitrary packets with any claimed source IP address
 - Egress filtering and unicast reverse path forwarding are some techniques that routers use to filter packets that appear to be coming from locations not expected on this path
- Packet fragmentation attacks
 - IP packets may need to be fragmented for various reasons. Such fragments need to be finally reassembled
 - Some operating systems may not handle incorrect assembly well and may malfunction – The “teardrop” attack is an example
 - If packet fragments are crafted to be overlapping, part of an attack and some random data can be sent in say fragment A and the remainder sent in packet B. An IDS will not recognize that the part code in A is an attack, but reassembly after the IDS may cause B to be overwritten over the random data so the now A has the full attack.

IPsec

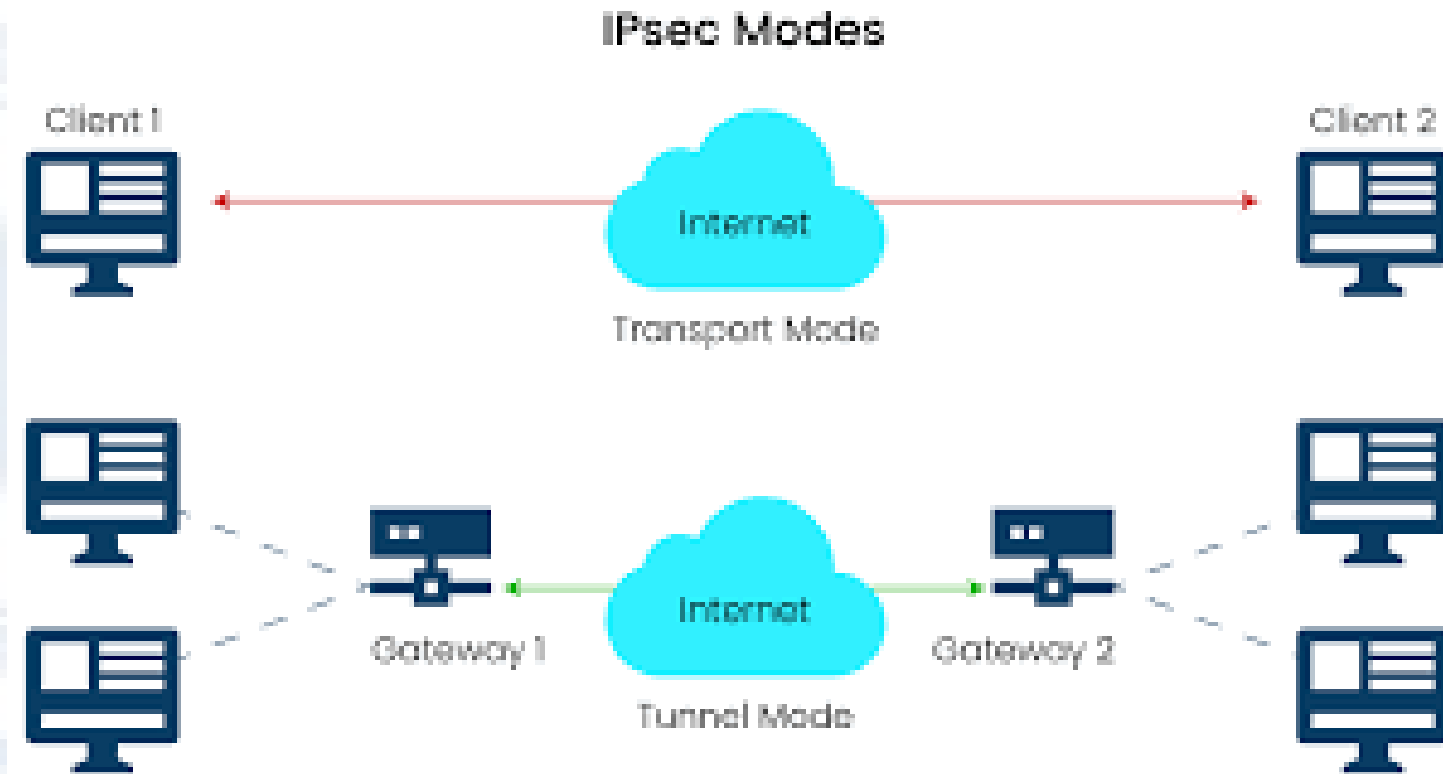
IPsec is a protocol that encrypts IP packets

IPsec provides confidentiality to the payload and can be used to implement Virtual Private Networks

IPsec can be deployed in two modes – Transport Mode and Tunnel Mode



IPsec deployment



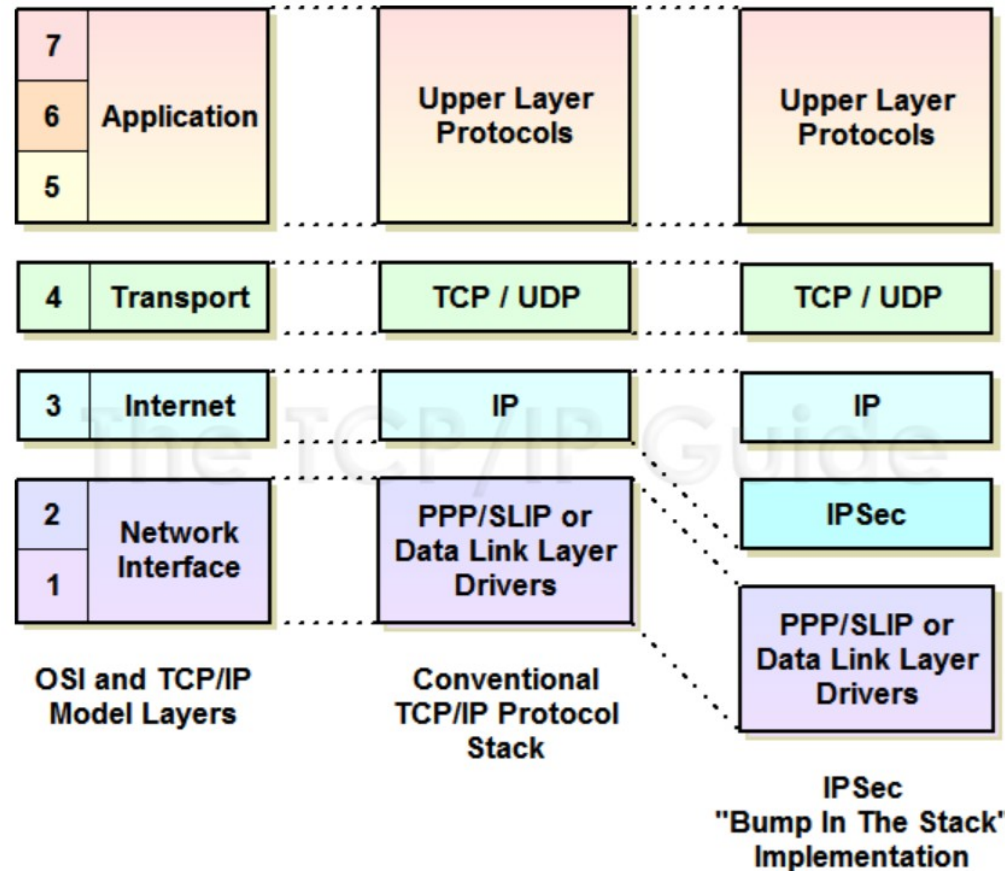
IPsec implementation architectures

- Integrated architecture – This is the ideal situation and is what happens in IPv6 since IPV6 natively supports IPsec
- Bump in the stack (BITS) – An additional layer is introduced into the network stack
- Bump in the wire (BITW) – A dedicated hardware device placed in a network path

BITS and BITW are conceptually the same thing but in one the changes are in the software stack of all endpoints and in the other they are in specialized hardware devices

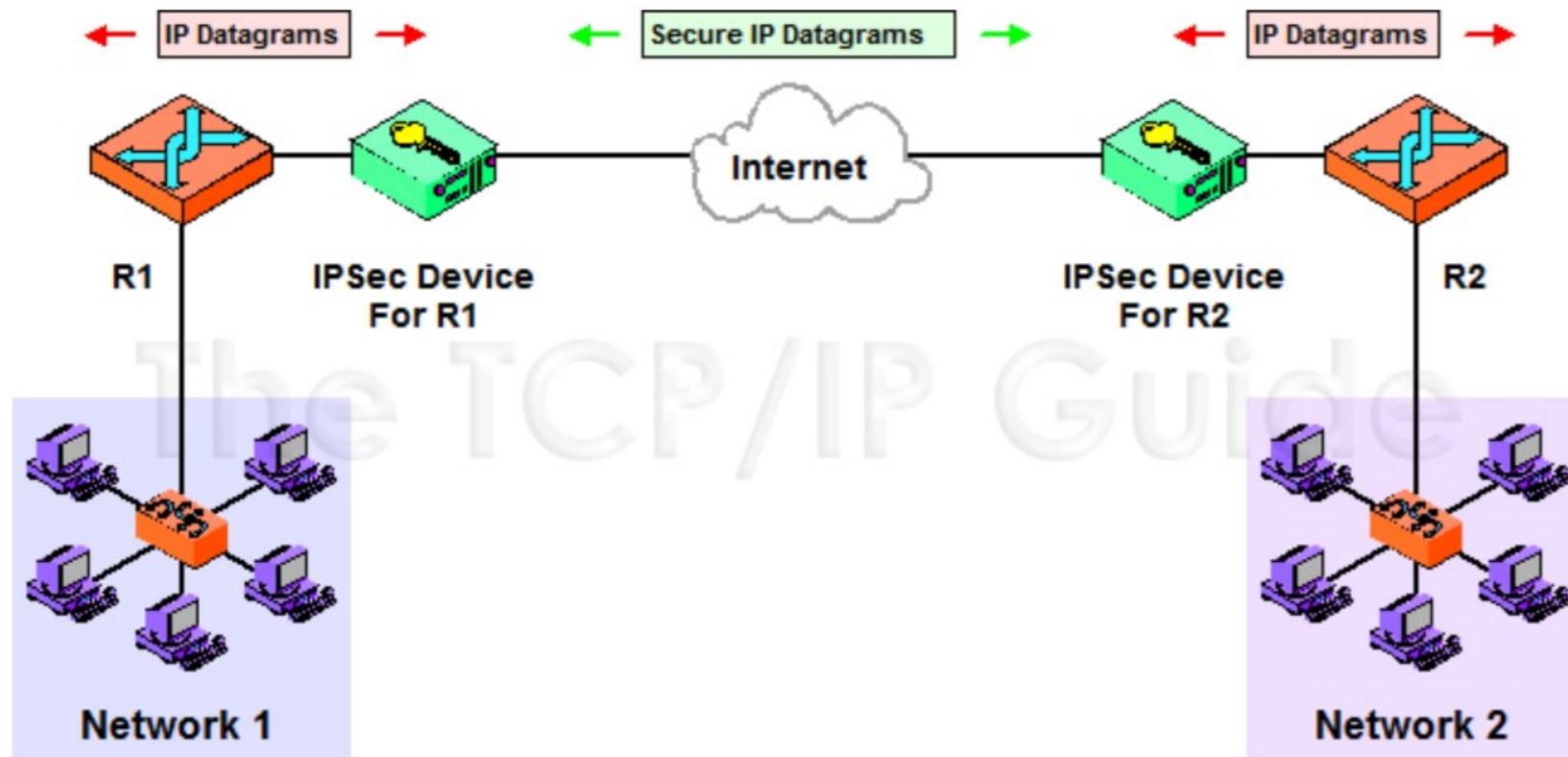
IPsec - BITS (Bump In The Stack)

http://www.tcpipguide.com/free/t_IPSecArchitecturesandImplementationMethods-2.htm



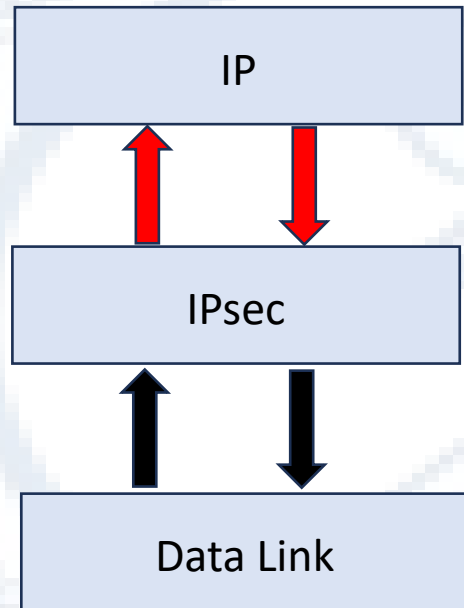
IPsec - BITW (Bump In The Wire)

http://www.tcpipguide.com/free/t_IPSecArchitecturesandImplementationMethods-3.htm



IPsec security associations

- Encryption on way down – Outbound traffic
- Decryption on way up – Inbound traffic



Security Association Database

SPI	Destination Address	Protocol
...		
...		
...		
....		

- Inspect each packet and see if it matches a destination
- If so, apply the processing specified for that destination
- IPsec SAs are unidirectional

Link Layer Security

- LAN Security
 - MACSEC for confidentiality
 - Port based access control (IEEE 802.1X)
- WAN link layer security
 - PPP and PPPoE
 - Authentication by protocols such as PAP, CHAP
- Network Segmentation
 - VLANs

Wireless Network Security

- The broadcast nature of wireless networks simplifies the process of eavesdropping so security becomes very important
- There have been several failed attempts to address this in wireless LANS
 - WEP – used RC4 as the encryption algorithm which was shown to be crackable using Fluhrer, Martin Shamir attacks. Also the linear CRC for error detection masked certain malicious modifications
 - WPA replaced WEP but maintained RC4 (for backward compatibility) with a different key derivation method
 - WPA evolved to WPA-2 that uses the AES-128 bit encryption algorithm
 - WPA-3 was designed to eventually replace WPA-2
 - WPA-3 Personal uses 128 bit encryption
 - WPA-3 Enterprise uses 192 bit encryption

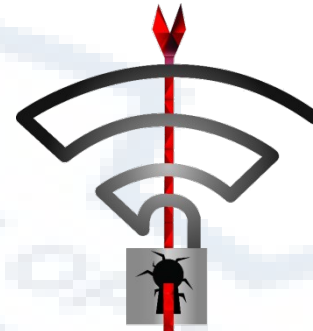
Attacks on network security protocols

- Successful large scale attacks on widely deployed network security protocols have occurred
- Two well known attacks were
 - Heartbleed
 - Krack



Heartbleed

- A bug discovered in the heartbeat implementation in SSL/TLS using OpenSSL
- Publicly disclosed on 7th April 2014
- A fix was made available on the same day
- Allowed an attacker to read the memory of a vulnerable system
- In August 2014, it was made public that the Heartbleed vulnerability enabled hackers to steal security keys from Community Health Systems, the second-biggest for-profit U.S. hospital chain in the United States, compromising the confidentiality of 4.5 million patient records. The breach happened a week after Heartbleed was first made public



Krack

- **KRACK ("Key Reinstallation Attack")** is a replay attack (a type of exploitable flaw) on the Wi-Fi Protected Access protocol that secures Wi-Fi connections. It was discovered in 2016.
- By repeatedly resetting the nonce transmitted in the third step of the WPA2 handshake, an attacker can gradually match encrypted packets seen before and learn the full keychain used to encrypt the traffic
- The widely used open-source implementation `wpa_supplicant`, utilized by Linux and Android, was especially susceptible as it can be manipulated to install an all-zeros encryption key, effectively nullifying WPA2 protection in a man-in-the-middle attack. Version 2.7 fixed this vulnerability.
- The security protocol protecting many Wi-Fi devices can essentially be bypassed, potentially allowing an attacker to intercept sent and received data
- In October 2018, reports emerged that the KRACK vulnerability was still exploitable in spite of vendor patches, through a variety of workarounds for the techniques used by vendors to close off the original attack

The background of the slide features a large, light blue watermark of the Indian Institute of Technology Bombay logo. The logo is a gear-like shape with a lotus flower in the center. The text "INDIAN INSTITUTE OF TECHNOLOGY BOMBAY" is written in a circular path around the lotus. At the bottom, there is a banner with the Sanskrit motto "सत्यम् धर्मम् विद्यया" (Satyam Dharmam Vidhyaya).

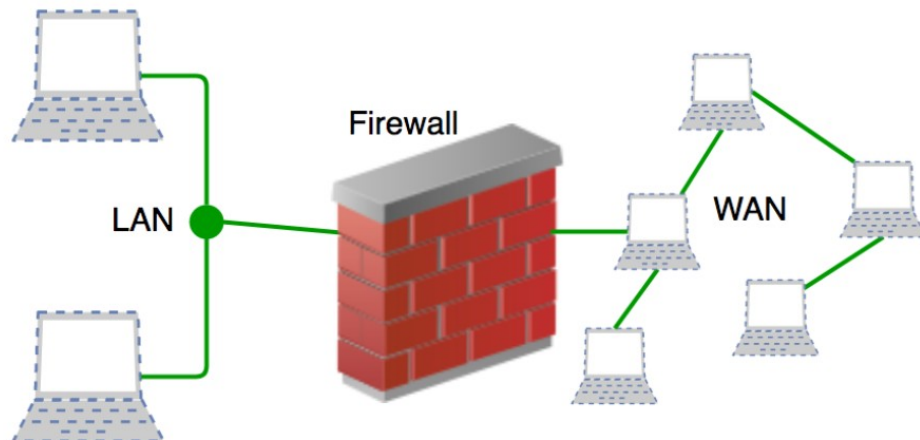
Network Security Tools

Network Security

Firewalls

A firewall monitors all incoming and outgoing IP packets and takes one of the following 3 basic actions depending upon the configured rules

- Allow the packet to pass
- Reject the packet but with some sort of message to the sender
- Drop the packet with no communication to the sender

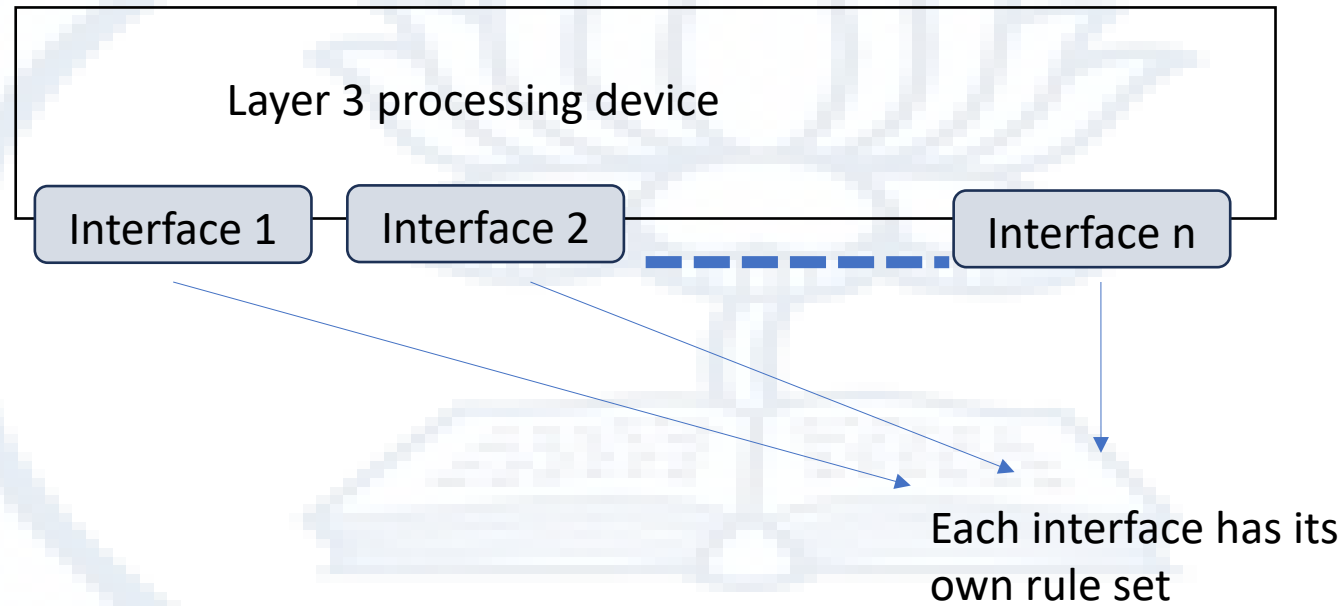


	Source IP	Dest. IP	Source Port	Dest. Port	Action
1	192.168.21.0	--	--	--	deny
2	--	--	--	23	deny
3	--	192.168.21.3	--	--	deny
4	--	192.168.21.0	--	>1023	Allow

Sample Packet Filter Firewall Rule

- Incoming packets from network 192.168.21.0 are blocked.
- Incoming packets destined for the internal TELNET server (port 23) are blocked.
- Incoming packets destined for host 192.168.21.3 are blocked.
- All well-known services to the network 192.168.21.0 are allowed.

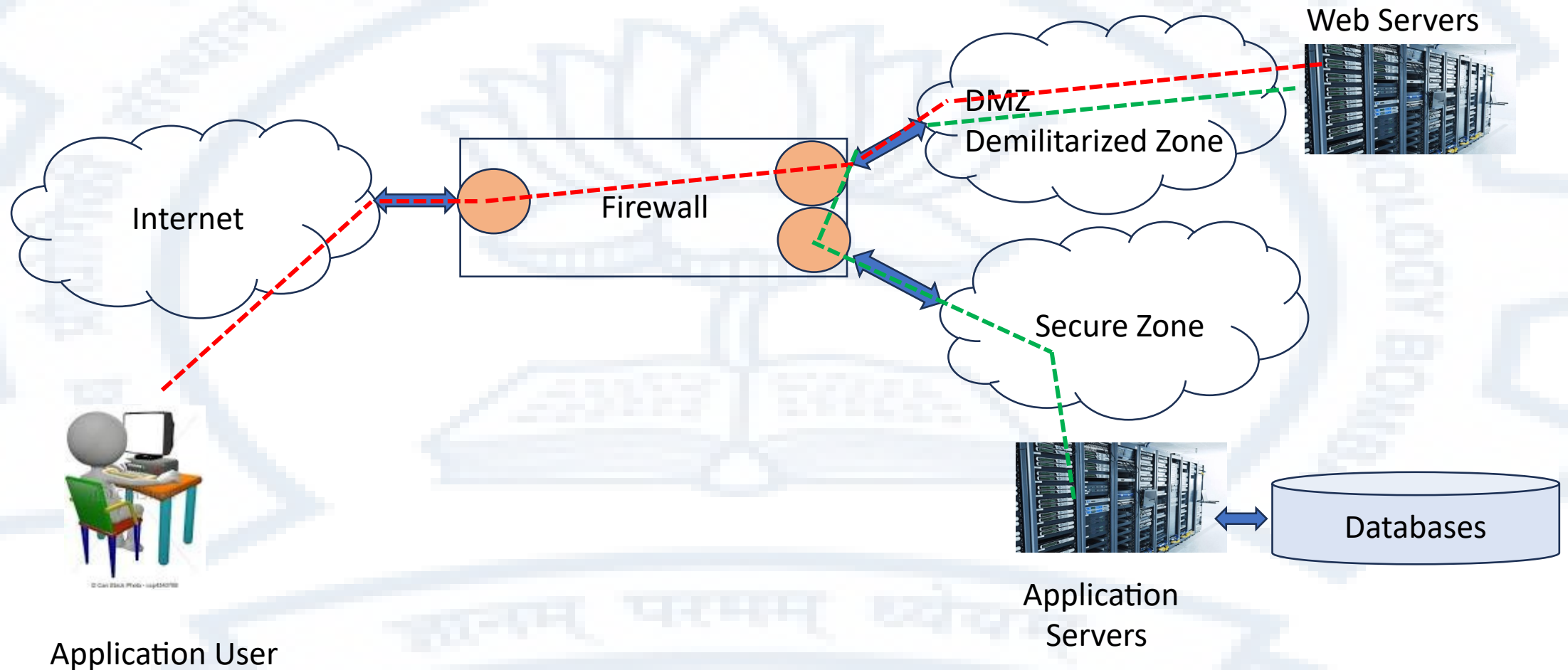
Generalized Firewall Architecture



This concept can be applied at any layer

- Layer 2 – VLAN device
- Layer 7 – WAF (Web Application Firewall)

A Typical Firewall Deployment Scenario



Intrusion Detection/Protection Systems (IDS/IPS)

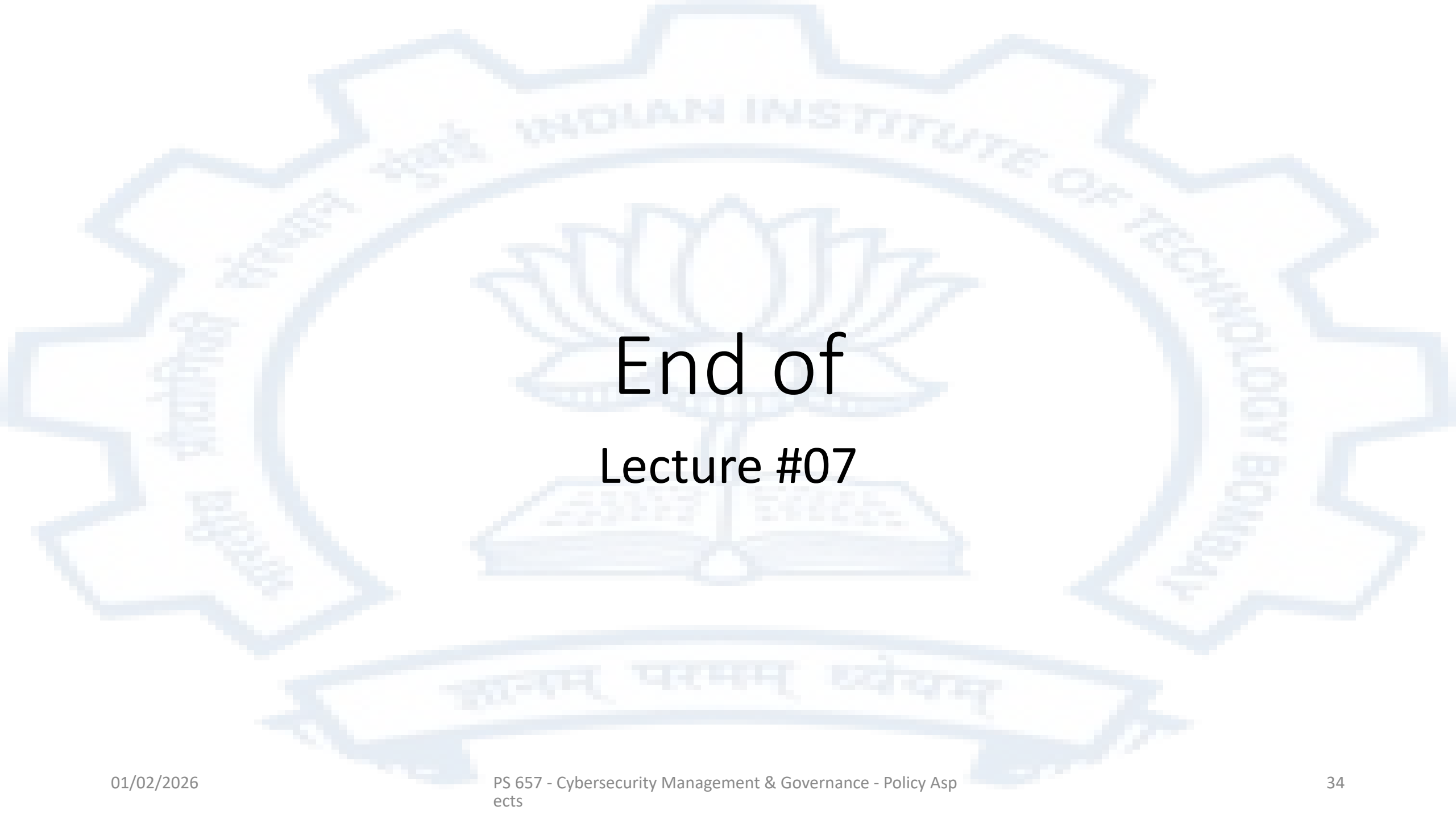
- Monitors network traffic
 - Looks at more attributes than a firewall
- Intrusion detection is usually done in one of the following two ways
 - Signature based : Looks for certain data patterns than indicate an attack
 - Anomaly based : Maintain a baseline of what is “normal” traffic and what could possibly be an anomaly
- Accuracy of intrusion detection system is a significant operational challenge
- An Intrusion Prevention System may take action after detecting a possible intrusion rather than just providing an alert
 - A possible action could be to block traffic from the source that the attack appears to be coming from
 - The IPS mode is not that frequently deployed due to its possible disruptive consequences and the accuracy of intrusion detection itself

Network Monitoring Systems

- Network Flow monitoring
 - An intermediate point on the spectrum of no recording to full traffic recording
 - Netflow is the most well known standard
- Network scanning
 - Nmap, Zmap – ICMP and SYN probes
- IP telescopes
 - Permit the monitoring of traffic in IP ranges that may not host any services
- Honeypots
 - Decoy servers placed as baits for potential attackers
- SIEM – Security Information and Event Management
 - Consolidates logs and alerts from various devices and correlates these to detect attacks

To summarize

- The basic computer networking protocols were not designed with security in mind. The protocols include Ethernet, IP, TCP and HTTP
- Security network connections means
 - Ensuring that data cannot be eavesdropped upon
 - Ensuring that malicious entities cannot modify data in transit
 - Ensuring that any device that connects to a network is adequately authenticated before allowing it to connect
- Several tools are available to ensure network security and manage the flow of data. Some of these tools are
 - Cryptographic network protocols
 - Firewalls
 - IDS/IPS systems
 - Network monitoring systems

The background of the slide features a large, light blue watermark of the Indian Institute of Technology Bombay logo. The logo is circular with a gear-like outer border. Inside the circle, there is a lotus flower in the center, and a banner at the bottom with the Sanskrit motto 'सत्यम् धर्मम् विद्यम्'. The text 'INDIAN INSTITUTE OF TECHNOLOGY BOMBAY' is written along the inner circle.

End of Lecture #07